Bartosz LEWANDOWSKI
Atende S.A.

OCHRONA PRZED WYCIEKIEM DANYCH: ROLA SYSTEMÓW DLP W WIELOWARSTWOWYM MODELU CYBERBEZPIECZEŃSTWA

DATA LEAK PROTECTION: THE ROLE OF DLP SYSTEMS IN A MULTI-LAYERED CYBERSECURITY MODEL

Abstrakt: Przedmiotem rozważań jest rola systemów zapobiegania wyciekom danych (DLP) w wielowarstwowym modelu cyberbezpieczeństwa. Rozważania mają charakter przeglądowo-koncepcyjny i opierają się na literaturze naukowej, przepisach RODO oraz raportach branżowych. Wyciek danych potraktowano jako skutek łańcucha zdarzeń, w którym błędy użytkowników nakładają się na luki organizacyjne i techniczne. Do opisu tego zjawiska wykorzystano model sera szwajcarskiego J. Reasona. Przedstawiono mechanizmy DLP: klasyfikację informacji, ochronę danych w trzech stanach, analizę treści i kontekstu oraz stopniowanie reakcji. Porównano zakres DLP z systemami EDR, NDR i SIEM. Zaproponowano ujęcie DLP jako uzupełnienia triady widoczności SOC o perspektywę chronionych informacji. Omówiono warunki skutecznego wdrożenia oraz finansowe, prawne i społeczne konsekwencje wycieków. Analiza wskazuje, że DLP skutecznie ogranicza wycieki przypadkowe, ale nie zastępuje innych warstw ochrony i wymaga wsparcia procedur organizacyjnych.

Słowa kluczowe: zapobieganie wyciekom danych, DLP, poufność informacji, wielowarstwowa ochrona, SOC, model sera szwajcarskiego, RODO

Abstract: The article discusses the role of data loss prevention (DLP) systems in a multi-layered cybersecurity model. It is a review and conceptual study based on scientific literature, the GDPR and industry reports. A data leak is treated as the outcome of a chain of events in which user errors coincide with organisational and technical gaps, described with J. Reason's Swiss cheese model. The article presents the mechanisms of DLP: information classification, protection of data in three states, content and context analysis, and graduated response. It compares the scope of DLP with EDR, NDR and SIEM systems and proposes to view DLP as a complement to the SOC visibility triad, adding the perspective of protected information. The conditions for effective deployment and the financial, legal and social consequences of leaks are discussed. The analysis shows that DLP effectively limits accidental leaks, but does not replace other layers of protection and requires the support of organisational procedures.

Key words: data loss prevention, DLP, information confidentiality, defence in depth, SOC, Swiss cheese model, GDPR

1. Wprowadzenie

Poufność należy, obok integralności i dostępności, do podstawowych właściwości chronionych w systemach bezpieczeństwa informacji. Jej naruszenie trudno odwrócić. Zniszczone dane można odtworzyć z kopii zapasowej, natomiast danych raz ujawnionych nie da się ponownie uczynić poufnymi.

Organizacje przetwarzają informacje jednocześnie na stacjach roboczych, w usługach chmurowych, w poczcie elektronicznej, w narzędziach do współpracy i w systemach partnerów. Każde z tych miejsc może stać się kanałem wycieku. Zapory sieciowe i systemy kontroli dostępu rozstrzygają, kto i skąd może się połączyć. Nie oceniają jednak, czy konkretna treść powinna opuścić organizację. Tę funkcję pełnią systemy zapobiegania wyciekom danych (ang. *Data Loss Prevention*, DLP). Są to narzędzia, które rozpoznają informacje chronione w treści i kontekście operacji na danych, takich jak zapis na nośniku, wysłanie wiadomości czy przesłanie pliku do usługi

chmurowej. Zależnie od przyjętej polityki rejestrują taką operację, ostrzegają użytkownika albo ją blokują[1].

Samo wdrożenie takiego narzędzia nie zapewnia jednak ochrony. DLP rozpoznaje treść, ale nie zastępuje systemów obserwujących urządzenia, sieć i dzienniki zdarzeń. Jego skuteczność zależy od tego, czy organizacja wie, jakie informacje chroni, i czy potrafi utrzymać reguły bez mnożenia wyjątków. Wyciek rzadko jest skutkiem pojedynczego błędu. Zwykle kończy łańcuch zdarzeń, w którym kolejne zabezpieczenia okazały się niewystarczające. Dlatego DLP warto rozpatrywać jako jedną z warstw wielowarstwowego modelu cyberbezpieczeństwa, a jego wartość oceniać na tle zagrożeń, które ma ograniczać, i kosztów, które pojawiają się, gdy ochrona zawiedzie. Punktem wyjścia jest pytanie, dlaczego kanałów wycieku wciąż przybywa.

2. Geneza i współczesne uwarunkowania wycieków danych

Ryzyko wycieku rośnie wraz z liczbą miejsc, w których informacja jest przechowywana i przez które przepływa. Long Cheng, Fang Liu i Danfeng Yao wiążą je z potrzebą gromadzenia i analizowania coraz większych zbiorów danych oraz z intensywnym korzystaniem z nowoczesnych kanałów komunikacji[2]. Autorzy wymieniają wśród możliwych wektorów wycieku m.in. usługi udostępniania plików w chmurze, pocztę elektroniczną, komunikatory, nośniki wymienne, podatności baz danych, kradzież laptopów, utratę kopii zapasowych i serwisy społecznościowe. Lista ta pokazuje, że wyciek nie jest zjawiskiem jednego kanału.

Praca rozproszona przesunęła przetwarzanie danych poza siedzibę organizacji. Ten sam przegląd wskazuje, że współdzielenie danych z partnerami i klientami, współpraca przez chmurę oraz praca poza siedzibą firmy zwiększają prawdopodobieństwo wycieku[3]. Nowsze dane potwierdzają znaczenie podmiotów zewnętrznych. Według komunikatu Verizon dotyczącego raportu *Data Breach Investigations Report* (DBIR) z 2026 roku, opartego na danych z 2025 roku, udział strony trzeciej odnotowano w 48% analizowanych naruszeń, a wskaźnik ten wzrósł o 60% względem poprzedniej edycji[4]. Granica organizacji przestaje więc pokrywać się z granicą jej sieci.

Narzędzia generatywnej sztucznej inteligencji tworzą kolejny kanał przepływu informacji. Ten sam komunikat podaje, że korzystanie przez pracowników z niezatwierdzonych narzędzi sztucznej inteligencji (ang. *artificial intelligence*, AI), określane jako *shadow AI*, stało się trzecią najczęstszą niezłośliwą aktywnością związaną z wyciekiem danych. Odsetek pracowników często korzystających z takich narzędzi wzrósł w ciągu roku z 15% do 45%[5]. Z perspektywy

[1] S. Alneyadi, E. Sithirasenan, V. Muthukkumarasamy, *A survey on data leakage prevention systems*, „Journal of Network and Computer Applications" 2016, t. 62, https://doi.org/10.1016/j.jnca.2016.01.008.

[2] L. Cheng, F. Liu, D. Yao, *Enterprise data breach: causes, challenges, prevention, and future directions*, „WIREs Data Mining and Knowledge Discovery" 2017, t. 7, nr 5, e1211, https://doi.org/10.1002/widm.1211.

[3] Tamże.

[4] Verizon, *Vulnerability exploitation top breach entry point, 2026 industry-wide DBIR finds*, informacja prasowa dotycząca raportu *2026 Data Breach Investigations Report*, 19 maja 2026, https://www.verizon.com/about/news/breach-industry-wide-dbir-finds (dostęp 21.10.2026 r.).

[5] Tamże.

ochrony informacji wklejenie dokumentu do zewnętrznej usługi jest przekazaniem danych poza kontrolę organizacji, niezależnie od intencji użytkownika. Ta interpretacja wyjaśnia, dlaczego problem dotyczy bardziej polityk ochrony danych niż samej technologii AI.

Wyciek może mieć trzy różne źródła: działanie napastnika, celowe nadużycie uprawnień przez osobę z wewnątrz organizacji (ang. *insider*), czyli pracownika lub współpracownika mającego uprawniony dostęp do jej zasobów, albo niezamierzony błąd. Cheng i współautorzy porządkują je według dwóch kryteriów: intencji (celowe lub przypadkowe) oraz pochodzenia sprawcy (wewnętrzny lub zewnętrzny)[6]. Do zagrożeń przypadkowych zaliczają m.in. omyłkową publikację, błąd konfiguracji, niewłaściwe szyfrowanie i utratę komputera. Obie grupy mają polskie przykłady. W 2024 roku Prezes UODO nałożył ponad 238 tys. zł kary na spółkę, której pracownik zgubił pendrive z niezaszyfrowanymi danymi osobowymi innego pracownika[7]. Organ wskazał, że administrator uwzględnił w analizie ryzyka kradzież i zniszczenie nośnika, ale pominął jego zwykłą utratę. W sprawie spółki Fortum Marketing and Sales Polska źródłem naruszenia był błąd konfiguracji. Podmiot przetwarzający utworzył podczas zmian w systemie dodatkową bazę danych klientów na serwerze bez odpowiednio skonfigurowanych zabezpieczeń. Osoby nieuprawnione skopiowały tę bazę, a administrator dowiedział się o incydencie od internautów[8].

Podział ten ma konsekwencje praktyczne. Napastnik zewnętrzny musi najpierw uzyskać dostęp, osoba z wewnątrz już go ma, a pracownik popełniający błąd nie ukrywa swoich działań. Każdy z tych scenariuszy pozostawia inne ślady i wymaga innego sposobu wykrywania.

3. Charakterystyka zagrożeń w świetle badań i raportów

Obraz zagrożeń opiera się w dużej mierze na raportach branżowych, ponieważ organizacje rzadko udostępniają dane o własnych incydentach badaczom akademickim. Dwie najczęściej przywoływane serie to DBIR firmy Verizon oraz *Cost of a Data Breach* przygotowywany przez Ponemon Institute na zlecenie IBM. Obie serie mają odmienną metodykę, więc ich wyniki należy czytać osobno.

Raport DBIR 2026 wskazuje wykorzystanie podatności jako najczęstszy punkt wejścia. Odpowiada ono za 31% naruszeń i po raz pierwszy w historii raportu wyprzedziło użycie skradzionych poświadczeń[9]. Ten sam komunikat podaje, że socjotechnika prowadzona kanałami mobilnymi (wiadomości tekstowe, połączenia głosowe) osiąga skuteczność o 40% wyższą niż tradycyjny phishing, czyli wyłudzanie danych w wiadomościach e-mail podszywających się pod zaufanego nadawcę. Dane te dotyczą głównie ataków zewnętrznych, ale pokazują też, że

[6] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.

[7] Urząd Ochrony Danych Osobowych, *Prawie 240 tys. zł kary dla firmy, której pracownik zgubił pendrive z danymi osobowymi*, komunikat dotyczący decyzji Prezesa UODO DKN.5131.29.2023, 17 maja 2024, https://uodo.gov.pl/pl/138/3095 (dostęp 28.10.2026 r.).

[8] Urząd Ochrony Danych Osobowych, *Rekordowa kara dla administratora za naruszenie ochrony danych*, komunikat dotyczący decyzji Prezesa UODO DKN.5130.2215.2020, 28 lutego 2022, https://uodo.gov.pl/pl/138/2389 (dostęp 28.10.2026 r.).

[9] Verizon, *Vulnerability exploitation top breach entry point*, dz. cyt.

użytkownik pozostaje częstym celem ataku.

Udział osób z wewnątrz organizacji trudniej oszacować, ponieważ zależy on od przyjętej definicji i źródła danych. Pełna wersja raportu DBIR 2026 obejmuje ponad 22 tys. potwierdzonych naruszeń z okresu od listopada 2024 do października 2025 roku. Sprawcy wewnętrzni wystąpili w 12% z nich, wobec 18% w poprzedniej edycji[10]. Autorzy raportu zaznaczają, że większość tych przypadków to pomyłki, błędy konfiguracji i obchodzenie procedur, a nie sabotaż. Umyślne nadużycie uprawnień odpowiadało za niespełna 4% naruszeń. Najczęstszym motywem w tej grupie była wygoda (60%), np. przesłanie danych służbowych na prywatną skrzynkę w celu pracy z domu[11]. Inaczej wygląda administracja publiczna. Sprawcy wewnętrzni odpowiadali tam za 44% naruszeń, głównie z powodu korespondencji doręczonej niewłaściwemu adresatowi, która stanowiła 88% błędów w tym sektorze[12].

Inną perspektywę daje badanie Ponemon Institute przeprowadzone na zlecenie firmy DTEX Systems wśród 8750 specjalistów IT i bezpieczeństwa z 354 organizacji, które doświadczyły incydentów wewnętrznych. W 2025 roku 53% tych incydentów wynikało z zaniedbań pracowników lub kontraktorów, 27% z działań celowych, a 20% z kradzieży poświadczeń. Średni roczny koszt obsługi incydentów wewnętrznych wyniósł 19,5 mln USD na organizację[13]. Próba obejmuje wyłącznie organizacje dotknięte takimi incydentami, więc wyniki nie opisują ogółu przedsiębiorstw. Oba źródła, mimo odmiennej metodyki, prowadzą do zbieżnego wniosku: po stronie wewnętrznej przeważa błąd lub zaniedbanie osoby z uprawnionym dostępem, a nie działanie w złej wierze. Przegląd systematyczny 121 prac opublikowanych w latach 2014–2025 wskazuje jednocześnie na lukę badawczą. Niewiele metod wykrywania zagrożeń wewnętrznych uwzględnia czynniki ludzkie, przede wszystkim z powodu braku zbiorów danych łączących informacje o zachowaniu i kontekście użytkownika. Autorzy przeglądu podkreślają potrzebę takich modeli zwłaszcza dla zagrożeń nieumyślnych[14].

Czynniki ludzkie, techniczne i organizacyjne występują zwykle łącznie. W ujęciu Chenga i współautorów przypadkowe wycieki wynikają głównie ze słabo zaprojektowanych procesów biznesowych, czyli z braku odpowiednich technologii zapobiegawczych i polityk bezpieczeństwa, albo z przeoczenia ze strony pracownika[15]. Błąd użytkownika jest tu więc objawem, a nie jedyną przyczyną. Podobnie można odczytać dane IBM: tylko 37% organizacji dotkniętych naruszeniem zadeklarowało szyfrowanie danych wrażliwych zarówno w spoczynku, jak i podczas przesyłania[16].

[10] Verizon Business, *2026 Data Breach Investigations Report*, 2026, https://www.verizon.com/business/resources/T343/reports/2026-dbir-data-breach-investigations-report.pdf (dostęp 26.10.2026 r.), s. 22.
[11] Tamże, s. 57–58.
[12] Tamże, s. 89, 92.
[13] Ponemon Institute, *2026 Cost of Insider Risks: Global*, omówienie raportu *2026 Cost of Insider Risks Global Report* przygotowanego na zlecenie DTEX Systems, 13 maja 2026, https://ponemonsullivanreport.com/2026/05/2026-cost-of-insider-risks-globa (dostęp 26.10.2026 r.).
[14] N. Pathirana i in., *Integrating Human Factors into Insider Threat Detection: A Systematic Review*, „ACM Computing Surveys" 2026, t. 58, nr 10, https://doi.org/10.1145/3798089.
[15] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.
[16] IBM, *IBM Study: One in Four Malicious Breaches are AI-Enabled, Costing Companies $6 Million on Average*,

Typowe scenariusze wycieku obejmują wyprowadzenie danych przez złośliwe oprogramowanie po włamaniu, nadużycie uprawnień lub sabotaż ze strony insidera, błędną konfigurację zasobu, omyłkową publikację oraz utratę urządzenia z niezaszyfrowanymi danymi[17]. Kanałem może być sieć, punkt końcowy, usługa chmurowa albo nośnik fizyczny. Asaf Shabtai, Yuval Elovici i Lior Rokach traktują kanał wycieku jako jedną z osi klasyfikacji rozwiązań DLP, obok źródła wycieku i stanu danych[18].

Ograniczenia interpretacji statystyk

Statystyki naruszeń opisują różne zjawiska, choć często używają podobnych słów. DBIR odróżnia incydent, czyli zdarzenie naruszające poufność, integralność lub dostępność zasobu informacyjnego, od naruszenia, czyli incydentu zakończonego potwierdzonym ujawnieniem danych osobie nieuprawnionej[19]. Samo potencjalne narażenie danych nie spełnia tej definicji. Rozproszony atak odmowy usługi (ang. *Distributed Denial of Service*, DDoS), który przeciąża system i uniemożliwia korzystanie z niego, jest więc zwykle incydentem, ale nie naruszeniem.

Ogólne rozporządzenie o ochronie danych (RODO), czyli unijny akt prawny regulujący przetwarzanie danych osobowych, przyjmuje szersze pojęcie. Naruszenie ochrony danych osobowych obejmuje nie tylko nieuprawnione ujawnienie lub dostęp, ale także przypadkowe lub niezgodne z prawem zniszczenie, utracenie i zmodyfikowanie danych (art. 4 pkt 12)[20]. Zaszyfrowanie danych przez oprogramowanie wymuszające okup (ang. *ransomware*) bez ich wyprowadzenia może być naruszeniem w rozumieniu RODO, ale nie naruszeniem w rozumieniu DBIR. Wyciek rozumiany jest tu węziej, jako przekroczenie przez informację granicy, w której jej przetwarzanie jest uprawnione.

Różnice dotyczą też prób badawczych. DBIR opiera się na danych z dochodzeń prowadzonych przez Verizon i organizacje współpracujące[21], a nie na losowej próbie organizacji. Edycja raportu IBM z 2026 roku obejmuje 602 organizacje, które doświadczyły naruszenia od marca 2025 do lutego 2026 roku[22]. Odsetki z tych raportów opisują więc zbiór zbadanych naruszeń lub organizacji. Nie mówią o tym, jak często naruszenia dotykają ogółu przedsiębiorstw.

---

informacja prasowa dotycząca raportu *Cost of a Data Breach Report 2026* (Ponemon Institute, IBM), 29 lipca 2026, https://newsroom.ibm.com/2026-07-29-ibm-study-one-in-four-malicious-breaches-are-ai-enabled,-costing-companies-6-million-on-average (dostęp 21.10.2026 r.).

[17] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.

[18] A. Shabtai, Y. Elovici, L. Rokach, *A Survey of Data Leakage Detection and Prevention Solutions*, SpringerBriefs in Computer Science, Springer, New York 2012, https://doi.org/10.1007/978-1-4614-2053-8.

[19] Verizon Business, *2024 Data Breach Investigations Report: Appendices*, https://verizon.com/business/resources/reports/dbir/2024/appendix (dostęp 21.10.2026 r.).

[20] Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (ogólne rozporządzenie o ochronie danych) (Dz.Urz. UE L 119 z 4.05.2016, s. 1–88).

[21] Verizon Business, *2024 Data Breach Investigations Report*, dz. cyt.

[22] IBM, *IBM Study: One in Four Malicious Breaches are AI-Enabled*, dz. cyt.

4. Istota i zakres ochrony DLP

Termin DLP nie ma jednej, powszechnie przyjętej definicji. Sultan Alneyadi, Elankayer Sithirasenan i Vallipuram Muthukkumarasamy określają systemy DLP jako wyspecjalizowane mechanizmy wykrywania i zapobiegania wyciekom danych poufnych w trakcie ich używania, przesyłania i przechowywania[23]. Zwracają jednocześnie uwagę, że samo pojęcie pozostaje niejednoznaczne, mimo rosnącej liczby produktów komercyjnych. Cheng i współautorzy używają szerszego określenia DLPD (ang. *Data Leak Prevention and Detection*) i przypisują tym systemom trzy zadania: identyfikację, monitorowanie i zapobieganie ujawnieniu informacji wrażliwych, zarówno celowemu, jak i przypadkowemu[24].

DLP różni się od podstawowych zabezpieczeń przedmiotem kontroli. Zapory sieciowe, oprogramowanie antywirusowe, systemy wykrywania włamań, kontrola dostępu i szyfrowanie chronią systemy i kanały. DLP ocenia treść lub kontekst samych danych[25]. Cheng i współautorzy formułują też wymagania wobec praktycznego systemu DLP. Powinien blokować tylko przepływy zawierające informacje wrażliwe i przepuszczać zwykły ruch. Powinien chronić przed nieostrożnymi pracownikami i złośliwymi insiderami. Powinien też utrudnić wyprowadzenie danych nawet wtedy, gdy zawiodą inne zabezpieczenia.

Identyfikacja i klasyfikacja informacji

System DLP może chronić tylko te informacje, które organizacja wcześniej rozpoznała i opisała. Ochrona poufności zaczyna się więc nie od wyboru narzędzia, lecz od ustalenia, jakie dane organizacja przetwarza, gdzie się one znajdują, kto z nich korzysta i jakie byłyby skutki ich ujawnienia. Na tej podstawie dane przypisuje się do kategorii, na przykład publicznych, wewnętrznych, poufnych i ściśle chronionych, a każdej kategorii przyporządkowuje zasady przetwarzania. Dopiero tak opisane zasoby można przełożyć na reguły systemu DLP. Klasyfikacja nie jest przy tym czynnością jednorazową, ponieważ powstają nowe zbiory danych, systemy i kanały ich wymiany. Wyznacza ona zakres działania DLP. Błędy na tym etapie przenoszą się na wszystkie dalsze decyzje systemu: dane pominięte w klasyfikacji pozostają bez ochrony, a dane sklasyfikowane zbyt szeroko generują nadmiar alarmów.

Dane przechowywane, przesyłane i wykorzystywane

Klasyczny podział obejmuje trzy stany danych. Cheng i współautorzy przypisują każdemu z nich inny cel ochrony[26]. Skanowanie danych przechowywanych na serwerach pozwala znaleźć zasoby narażone na wyciek wewnątrz organizacji. Monitorowanie danych używanych na stacjach roboczych ma zapobiegać niewłaściwemu obchodzeniu się z nimi przez użytkowników. Monitorowanie ruchu sieciowego ma powstrzymać przesłanie danych poufnych poza sieć firmową. Shabtai i współautorzy włączają stan danych do taksonomii rozwiązań, obok źródła wycieku,

[23] S. Alneyadi, E. Sithirasenan, V. Muthukkumarasamy, *A survey on data leakage prevention systems*, dz. cyt.
[24] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.
[25] Tamże.
[26] Tamże.

kanału, sposobu wdrożenia, charakteru działania (zapobiegawczy lub wykrywający) i reakcji na wyciek[27].

Analiza treści i kontekstu

Systemy DLP rozpoznają dane chronione na dwa sposoby: przez analizę treści albo przez analizę kontekstu[28]. Pierwsze podejście sprawdza, co zawiera przesyłany lub zapisywany obiekt. Drugie bada metadane i okoliczności operacji: kto ją wykonuje, skąd, dokąd, w jakim czasie i czy odbiega ona od typowego wzorca zachowania. Część rozwiązań łączy obie metody. Tabela 1 zestawia główne techniki wraz z ich ograniczeniami.

Tabela 1. Techniki wykrywania w systemach DLP

Technika	Rodzaj analizy	Zaleta	Ograniczenie
Odciski cyfrowe (*fingerprinting*)	treść	prosta implementacja, wykrywa całe dokumenty chronione	duża wrażliwość na modyfikację danych
Wyrażenia regularne	treść	dobre dla danych o przewidywalnym formacie (np. numery kart)	ograniczona ochrona, wysoki odsetek fałszywych alarmów
Porównywanie zbiorów n-gramów	treść	toleruje drobne zmiany tekstu	duży koszt obliczeń i pamięci
Uczenie maszynowe	treść lub kontekst	odporność na modyfikacje danych	potrzeba dużych zbiorów uczących, złożoność
Analiza zachowań	kontekst	ogranicza zagrożenia wewnętrzne	potrzeba dużych zbiorów uczących, wysoki odsetek fałszywych alarmów
Znakowanie wodne	kontekst	wspiera analizę powykonawczą	podatność na usunięcie lub zniekształcenie znaku

Źródło: opracowanie własne na podstawie: L. Cheng, F. Liu, D. Yao, *Enterprise data breach*.

Analiza treści skutecznie chroni przed przypadkową utratą danych, ale świadomy sprawca może ją ominąć przez zaciemnienie danych[29]. Ruch szyfrowany czyni ją bezużyteczną, jeżeli system nie ma wglądu w treść przed zaszyfrowaniem. Cheng i współautorzy przywołują też ocenę trzech rozwiązań komercyjnych przeprowadzoną przez Davida Gugelmanna i współautorów. Systemy te zapobiegały przypadkowym wyciekom w ruchu WWW, ale insider lub złośliwe oprogramowanie mogły je łatwo obejść. Wynik ten wyznacza realistyczny zakres oczekiwań wobec DLP.

Monitorowanie, ostrzeganie i blokowanie

Reakcja na wykrytą operację może mieć różną siłę. System może jedynie zarejestrować zdarzenie, ostrzec użytkownika i poprosić o uzasadnienie albo zablokować operację. Shabtai i współautorzy traktują działanie podejmowane po wykryciu wycieku jako odrębną oś klasyfika-

[27] A. Shabtai, Y. Elovici, L. Rokach, *A Survey of Data Leakage Detection and Prevention Solutions*, dz. cyt.
[28] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.
[29] Tamże.

cji rozwiązań[30]. Dobór reakcji jest decyzją organizacyjną, a nie wyłącznie techniczną. Blokada chroni dane, ale przy błędnej regule zatrzymuje też uprawnioną pracę.

5. Miejsce DLP w architekturze cyberbezpieczeństwa

DLP nie zastępuje innych narzędzi wykrywania zagrożeń, ponieważ obserwuje inny obiekt. Systemy EDR (ang. *Endpoint Detection and Response*) analizują telemetrię punktów końcowych: uruchamiane procesy, zmiany w systemie i aktywność na urządzeniu. Systemy NDR (ang. *Network Detection and Response*) analizują ruch sieciowy. Systemy SIEM (ang. *Security Information and Event Management*) gromadzą i korelują dzienniki zdarzeń z wielu źródeł. DLP ocenia natomiast, czy dana operacja dotyczy informacji chronionej i czy jest zgodna z polityką jej przetwarzania. Tabela 2 zestawia te różnice.

Tabela 2. Porównanie zakresów działania DLP, EDR, NDR i SIEM

Klasa rozwiązań	Przedmiot obserwacji	Pytanie, na które odpowiada	Typowa reakcja
DLP	treść i kontekst operacji na danych	czy ta informacja może opuścić dozwolony obszar?	rejestracja, ostrzeżenie użytkownika, blokada operacji
EDR	procesy i zmiany na punkcie końcowym	co dzieje się na urządzeniu?	izolacja hosta, zatrzymanie procesu
NDR	ruch sieciowy	kto, z kim i w jaki sposób się komunikuje?	alarm, wsparcie blokady połączenia
SIEM	dzienniki zdarzeń z wielu systemów	jak zdarzenia z różnych źródeł łączą się w całość?	korelacja, alarm, przekazanie do obsługi incydentu

Źródło: opracowanie własne.

Koncepcję trzech źródeł widoczności w centrum operacji bezpieczeństwa (ang. *Security Operations Center*, SOC), czyli zespole stale monitorującym zdarzenia i obsługującym incydenty, zaproponował w 2015 roku Anton Chuvakin, pracując wtedy jako analityk Gartnera[31]. Pierwotnie nazwał ją „jądrową triadą SOC", przez analogię do triady środków przenoszenia broni jądrowej. Trzy filary to dzienniki zdarzeń (SIEM), dane sieciowe i telemetria punktów końcowych (EDR). Dane sieciowe dostarczały pierwotnie narzędzia analizy ruchu (ang. *Network Traffic Analysis*, NTA), później określane jako NDR. Chuvakin zauważył później, że zakresy tych źródeł częściowo się pokrywają. Dopuścił też, że widoczność aplikacji może stać się czwartym filarem.

Triada odpowiada na pytanie, co dzieje się w infrastrukturze. Nie odpowiada wprost na pytanie, których informacji dotyczą obserwowane zdarzenia. Autor proponuje traktować DLP jako uzupełnienie triady o perspektywę chronionych danych. Nie jest to stanowisko Gartnera ani Chuvakina, lecz interpretacja proponowana w niniejszym tekście. Przykładowo EDR może od-

[30] A. Shabtai, Y. Elovici, L. Rokach, *A Survey of Data Leakage Detection and Prevention Solutions*, dz. cyt.

[31] A. Chuvakin, *Back in 2015, while working on a Gartner SOC paper, I coined the concept of „SOC nuclear triad"...*, *Anton on Security* (Medium), 2020; przedruk: Security Boulevard, wrzesień 2020, https://securityboulevard.com/2020/09/back-in-2015-while-working-on-a-gartner-soc-paper-i-coined-the-concept-of-soc-nuclear-triad/ (dostęp 21.10.2026 r.).

notować uruchomienie programu archiwizującego, a NDR wysyłkę dużego pliku do zewnętrznej usługi. Dopiero DLP może wskazać, że archiwum zawiera dokumenty oznaczone jako poufne.

Wartość tej perspektywy rośnie, gdy zdarzenia DLP trafiają do wspólnego procesu monitorowania. Cheng i współautorzy pokazują wiele punktów, w których można rozmieścić uzupełniające się techniki ochrony: na urządzeniach pracowników, serwerach pocztowych i WWW, styku z siecią zewnętrzną oraz w kontaktach z dostawcami i partnerami[32]. Przewodnik SP 1800-28, opublikowany przez amerykański National Institute of Standards and Technology (NIST), również opisuje rozwiązanie przykładowe złożone z wielu współpracujących systemów. Wykrywanie, reagowanie i odtwarzanie po naruszeniu poufności omówiono w nim jako osobny projekt (SP 1800-29)[33].

Integracja ma znaczenie praktyczne dla obsługi incydentów. Alarm DLP bez kontekstu z EDR lub SIEM trudno ocenić: nie wiadomo, czy użytkownik działał świadomie, czy jego konto zostało przejęte. Z kolei alarm EDR bez informacji o rodzaju danych utrudnia ocenę skutków incydentu. Połączenie obu perspektyw pozwala szybciej ustalić, czy doszło do wycieku i kogo dotyczy.

6. Od pojedynczego błędu do wycieku: kontekst i zachowania

Wyciek rzadko wynika z jednego działania. Dobrze to pokazuje analiza naruszenia w sieci handlowej Target z 2013 roku, przedstawiona przez Chenga i współautorów[34]. Napastnicy przejęli najpierw przez phishing system dostawcy usług technicznych, który miał zdalny dostęp do sieci Target. Następnie weszli do sieci firmy, zainstalowali złośliwe oprogramowanie na terminalach płatniczych, przenieśli zebrane dane na przejęte hosty wewnętrzne i wyprowadzili je na zewnątrz. Każdy z tych etapów był osobną okazją do przerwania ataku.

Autorzy wskazują cztery techniczne przyczyny tego naruszenia. Target nie stosował odpowiedniej kontroli dostępu wobec partnerów zewnętrznych. Nie odseparował systemu płatniczego od reszty sieci. Nie zabezpieczył terminali przed instalacją nieautoryzowanego oprogramowania. Miał wdrożone zapory i system zapobiegania włamaniom, ale nie zbadał ostrzeżeń, które te narzędzia wygenerowały[35]. Ostatnia przyczyna jest z perspektywy DLP najważniejsza. Zabezpieczenie zadziałało, a mimo to bariera zawiodła na poziomie organizacji.

Model sera szwajcarskiego

Taką sekwencję dobrze opisuje model sera szwajcarskiego Jamesa Reasona[36]. Reason przedstawia zabezpieczenia systemu jako kolejne warstwy. Część z nich jest techniczna (alarmy, bariery fizyczne, automatyczne wyłączenia), część opiera się na ludziach, a część na procedurach

[32] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.

[33] W. Fisher i in., *Data Confidentiality: Identifying and Protecting Assets Against Data Breaches*, NIST Special Publication 1800-28, National Institute of Standards and Technology, Gaithersburg, MD 2024, https://doi.org/10.6028/NIST.SP.1800-28.

[34] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.

[35] Tamże.

[36] J. Reason, *Human error: models and management*, „BMJ" 2000, t. 320, nr 7237, https://doi.org/10.1136/bmj.320.7237.768.

i kontroli administracyjnej. Każda warstwa ma luki, które otwierają się, zamykają i przesuwają. Luka w pojedynczej warstwie zwykle nie prowadzi do szkody. Szkoda powstaje dopiero wtedy, gdy luki w wielu warstwach chwilowo się pokryją.

Reason wyróżnia dwa źródła luk. Błędy aktywne to niebezpieczne działania osób mających bezpośredni kontakt z systemem: pomyłki, przeoczenia i naruszenia procedur. Warunki ukryte wynikają z decyzji projektantów, autorów procedur i kierownictwa. Mogą pozostawać niezauważone przez lata, zanim w połączeniu z błędem aktywnym umożliwią wypadek[37]. W odróżnieniu od błędów aktywnych warunki ukryte można wykryć i usunąć, zanim dojdzie do zdarzenia.

Analogia z bezpieczeństwem lotniczym ma tu podstawę w samym tekście Reasona. Autor powołuje się na dane z obsługi technicznej statków powietrznych, według których około 90% uchybień jakościowych uznano za niezawinione. Jako przykłady organizacji wysokiej niezawodności wymienia m.in. ośrodki kontroli ruchu lotniczego[38]. Reason podkreśla też, że skuteczne zarządzanie ryzykiem wymaga kultury zgłaszania błędów, a ta z kolei wymaga zaufania. Wniosek ten przenosi się na ochronę danych: pracownik, który obawia się kary, rzadziej zgłosi omyłkowe wysłanie dokumentu.

W ochronie przed wyciekiem danych błędem aktywnym może być wysłanie pliku do niewłaściwego odbiorcy. Warunkami ukrytymi mogą być nadmierne uprawnienia, brak klasyfikacji danych, nieodseparowane segmenty sieci albo brak procedury analizy alarmów. Przypadek Target pokazuje, że w praktyce występują one łącznie[39]. DLP jest w tym ujęciu jedną z warstw. Zmniejsza prawdopodobieństwo, że luki się pokryją, ale nie eliminuje luk w innych warstwach.

Analiza kontekstu i zachowań

Reguła oceniająca pojedynczą operację odpowiada na pytanie, czy ta operacja narusza politykę. Nie widzi jednak sekwencji. Rozważmy przykład hipotetyczny: pracownik pobiera w ciągu tygodnia więcej dokumentów niż zwykle, łączy je w archiwa i przesyła do prywatnej usługi chmurowej. Każda z tych czynności osobno może mieścić się w granicach uprawnień. Ryzyko ujawnia dopiero ich układ.

Analiza zachowań próbuje uchwycić takie układy przez modelowanie typowej aktywności użytkownika i wykrywanie odchyleń[40]. Cheng i współautorzy zaznaczają jednak dwa ograniczenia. Pierwszym jest wysoki odsetek fałszywych alarmów, wynikający ze zmienności kontekstu w czasie. Drugim jest luka semantyczna między obserwowalnymi zdarzeniami w systemie a intencjami użytkownika, których nie da się zmierzyć bezpośrednio. Insider działający w granicach swoich uprawnień pozostaje więc trudny do wykrycia.

Reakcja na pojedynczą operację i analiza sekwencji pełnią różne funkcje. Pierwsza zatrzymuje oczywiste naruszenia w chwili ich wystąpienia. Druga wskazuje sytuacje wymagające oceny przez analityka. Autor uważa, że łączenie obu poziomów jest właściwsze niż próba za-

[37] Tamże.
[38] Tamże.
[39] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.
[40] Tamże.

stąpienia jednego drugim. Blokowanie na podstawie samej analizy zachowań, przy obecnym poziomie fałszywych alarmów, zatrzymywałoby zbyt wiele uprawnionych działań.

7. Uwarunkowania wdrożenia i skuteczności DLP

Skuteczność DLP zależy bardziej od przygotowania organizacji niż od wyboru produktu. Równie istotnym czynnikiem sukcesu jest determinacja organizacji oraz odporność na wprowadzanie wyjątków do reguł. Kluczowe etapy wdrożeń można określić w następujący sposób.

Zakres ochrony i polityki

Wdrożenie powinno zaczynać się od określenia, które informacje wymagają ochrony i dlaczego. Kolejność przyjęta w procesie to najpierw identyfikacja zasobów i ryzyk, potem ochrona. Organizacja, która nie wie, gdzie przechowuje dane osobowe klientów lub dokumentację projektową, nie napisze dla nich trafnych reguł.

Polityki DLP powinny wynikać z klasyfikacji danych i z procesów biznesowych. Ta sama treść może być przesyłana zasadnie w jednym procesie i niedopuszczalnie w innym. Umowa z kontrahentem wysłana do jego działu prawnego jest operacją rutynową. Ta sama umowa wysłana na prywatny adres pracownika wymaga wyjaśnienia. Reguła oparta wyłącznie na treści nie odróżni tych przypadków. Potrzebny jest kontekst procesu.

Etapowe uruchamianie

Wdrożenie można podzielić na trzy etapy:

1. Obserwacja. System rejestruje zdarzenia bez ingerencji w pracę użytkowników. Organizacja poznaje rzeczywiste przepływy danych, które często różnią się od opisanych w procedurach.

2. Dostrajanie. Reguły są korygowane na podstawie zebranych zdarzeń. Użytkownicy otrzymują ostrzeżenia i mogą podać uzasadnienie operacji.

3. Blokowanie. Blokady obejmują najpierw reguły o niskim odsetku fałszywych alarmów i dane o najwyższej wrażliwości, a dopiero później kolejne kategorie.

Kolejność ta wynika z ograniczeń technik wykrywania. Wyrażenia regularne i analiza zachowań generują dużo fałszywych alarmów[41]. Natychmiastowe włączenie blokad zatrzymałoby więc część uprawnionej pracy. Użytkownicy zaczęliby wtedy szukać kanałów omijających kontrolę.

Fałszywe alarmy i wyjątki

Każdy fałszywy alarm kosztuje czas analityka i obniża zaufanie do systemu. Organizacja potrzebuje procedury rozpatrywania alarmów i przyznawania wyjątków. Wyjątek powinien

[41] Tamże.

mieć właściciela, uzasadnienie i termin ważności. Wyjątki bezterminowe stają się z czasem warunkami ukrytymi w rozumieniu Reasona[42]: luką, o której wszyscy zapomnieli.

Przypadek Target pokazuje drugą stronę tego problemu. Ostrzeżenia wygenerowane przez narzędzia bezpieczeństwa nie zostały zbadane[43]. System, który generuje alarmy, ale nie ma przypisanej odpowiedzialności za ich obsługę, daje poczucie ochrony bez rzeczywistej ochrony.

Odpowiedzialność i edukacja

DLP wymaga podziału ról. Właściciele danych określają, co jest chronione. Zespół bezpieczeństwa utrzymuje reguły i obsługuje alarmy. Kierownicy jednostek rozstrzygają o wyjątkach w swoich procesach. Dział prawny lub inspektor ochrony danych ocenia, czy zdarzenie jest naruszeniem wymagającym zgłoszenia.

Edukacja użytkowników ma w tym modelu konkretny cel. Cheng i współautorzy wskazują, że zapobieganie przypadkowym wyciekom wymaga, obok środków technicznych, budowania świadomości bezpieczeństwa w miejscu pracy[44]. Ostrzeżenie wyświetlane w chwili operacji może pełnić funkcję edukacyjną, jeżeli wyjaśnia, dlaczego operacja została zatrzymana. Wsparciem jest kultura zgłaszania błędów opisana przez Reasona[45].

Ocena skuteczności i ograniczenia modelu

Skuteczności DLP nie można mierzyć samą liczbą zablokowanych operacji. Duża liczba blokad może oznaczać skuteczną ochronę albo źle dobrane reguły. Autor proponuje kilka miar, które należy ocenić w przyszłych badaniach: odsetek alarmów uznanych po analizie za zasadne, czas od alarmu do decyzji analityka, udział sklasyfikowanych repozytoriów objętych monitorowaniem oraz liczbę aktywnych wyjątków bez wyznaczonego terminu.

Model ochrony oparty na DLP ma też granice. Analiza treści nie radzi sobie z danymi zaszyfrowanymi lub celowo zaciemnionymi. Insider działający w granicach swoich uprawnień może pozostać niewykryty. Brakuje też wspólnych zbiorów danych testowych, co utrudnia porównywanie metod wykrywania[46]. DLP ogranicza więc ryzyko wycieku, ale go nie usuwa.

8. Finansowe i społeczne konsekwencje wycieków

Koszt naruszenia obejmuje znacznie więcej niż usunięcie jego technicznej przyczyny. Według raportu IBM z 2026 roku średni globalny koszt naruszenia wyniósł 4,99 mln USD[47]. Wartość ta jest średnią dla 602 organizacji, które doświadczyły naruszenia od marca 2025 do lutego 2026 roku. Nie opisuje typowego kosztu w małej firmie ani w polskich realiach rynkowych. Średnia arytmetyczna jest też wrażliwa na pojedyncze bardzo kosztowne przypadki.

Na koszty składają się obsługa incydentu, analiza powykonawcza, przywracanie działalności, powiadomienia, wsparcie dla poszkodowanych i utracone przychody. Cheng i współautorzy

[42] J. Reason, *Human error*, dz. cyt.
[43] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.
[44] Tamże.
[45] J. Reason, *Human error*, dz. cyt.
[46] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.
[47] IBM, *IBM Study: One in Four Malicious Breaches are AI-Enabled*, dz. cyt.

przytaczają dwa przykłady skali takich skutków[48]. Target podał straty związane z naruszeniem z 2013 roku na poziomie 248 mln USD. Po ujawnieniu naruszeń w Yahoo Verizon zapłacił za przejęcie tej firmy o 350 mln USD mniej, niż pierwotnie planowano. Drugi przykład pokazuje, że naruszenie może obniżyć wartość przedsiębiorstwa w transakcji kapitałowej.

Konsekwencje prawne, kontraktowe i reputacyjne

W Unii Europejskiej wyciek danych osobowych uruchamia obowiązki określone w RODO[49]. Administrator zgłasza naruszenie organowi nadzorczemu bez zbędnej zwłoki, w miarę możliwości nie później niż w ciągu 72 godzin od jego stwierdzenia (art. 33). Jeżeli naruszenie może powodować wysokie ryzyko dla praw lub wolności osób fizycznych, administrator zawiadamia również te osoby (art. 34). Osoba, która poniosła szkodę majątkową lub niemajątkową, ma prawo do odszkodowania (art. 82). Za naruszenie przepisów rozporządzenia grozi administracyjna kara pieniężna, w najwyższym progu do 20 mln EUR lub do 4% całkowitego rocznego światowego obrotu przedsiębiorstwa (art. 83).

Obowiązek zgłoszenia w ciągu 72 godzin łączy się bezpośrednio z rolą DLP. Administrator musi w krótkim czasie ustalić, jakie dane zostały ujawnione i kogo dotyczą. Zdarzenia rejestrowane przez DLP, powiązane z klasyfikacją danych, mogą skrócić tę analizę. Jest to wniosek autora, a nie wymóg prawny.

Skutki kontraktowe i reputacyjne trudniej zmierzyć. Wyciek danych powierzonych przez kontrahenta może oznaczać naruszenie umowy i utratę klienta. Raport IBM wskazuje, że sprawcy ataków ransomware coraz częściej wywierają presję przez zagrożenie dla reputacji. Najczęściej wykorzystują reputację marki ofiary (41% przypadków), dane pracowników (35%) i własność intelektualną (31%)[50]. Reputacja staje się więc bezpośrednim narzędziem wymuszenia.

Utrata zaufania i skutki dla osób, których dane ujawniono

Wyciek narusza zaufanie klientów, pracowników i partnerów. Zaufanie odbudowuje się wolniej niż systemy informatyczne, a jego utraty nie oddają w pełni ani koszty obsługi incydentu, ani wysokość kar.

Najpoważniejsze skutki ponoszą osoby, których dane ujawniono. W incydencie australijskiego Red Cross Blood Service ujawnione dokumenty zawierały nie tylko imiona, adresy i daty urodzenia dawców. Obejmowały też informacje o aktywności seksualnej, przyjmowaniu narkotyków i historii chorób[51]. Takiej szkody nie da się naprawić zmianą hasła ani wydaniem nowej karty płatniczej. Ujawnienie danych identyfikacyjnych zwiększa z kolei ryzyko kradzieży tożsamości, która była typem szkody w części największych naruszeń zestawionych przez tych samych autorów.

Ochrona informacji jest więc odpowiedzialnością organizacyjną i społeczną. Organizacja

[48] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.
[49] RODO.
[50] IBM, *IBM Study: One in Four Malicious Breaches are AI-Enabled*, dz. cyt.
[51] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.

przetwarza dane osób, które zwykle nie mają wpływu na sposób ich zabezpieczenia. Skutki błędów ponoszą w dużej mierze ci, którzy ich nie popełnili.

9. Podsumowanie i wnioski

Systemy DLP wnoszą do wielowarstwowej ochrony informacji perspektywę, której nie zapewniają narzędzia triady widoczności SOC. EDR, NDR i SIEM opisują zdarzenia na urządzeniach, w sieci i w dziennikach systemów. DLP wiąże te zdarzenia z konkretnymi informacjami i z zasadami ich przetwarzania. Ta zdolność jest użyteczna zarówno w zapobieganiu wyciekom, jak i w ocenie skutków incydentu.

Przegląd literatury wskazuje jednocześnie wyraźne granice tej klasy rozwiązań. DLP skutecznie ogranicza wycieki przypadkowe, ale świadomy sprawca może obejść analizę treści przez zaciemnienie lub szyfrowanie danych[52]. Analiza zachowań rozszerza możliwości wykrywania zagrożeń wewnętrznych, lecz generuje wiele fałszywych alarmów. DLP należy więc traktować jako jedną z warstw ochrony, a nie jako rozwiązanie samodzielne.

Model sera szwajcarskiego[53] pozwala ująć wyciek jako skutek nakładania się błędów aktywnych i warunków ukrytych. Z tej perspektywy skuteczność DLP zależy od stanu pozostałych warstw: klasyfikacji danych, zakresu uprawnień, segmentacji sieci i procedur obsługi alarmów. Przypadek Target pokazuje, że zabezpieczenie techniczne może zadziałać prawidłowo, a mimo to nie zapobiec szkodzie, gdy nikt nie reaguje na jego sygnały[54].

Z przeprowadzonej analizy wynikają trzy wnioski praktyczne:

1. Projektowanie ochrony powinno zaczynać się od identyfikacji i klasyfikacji danych, a dopiero potem obejmować dobór technologii.

2. Wdrożenie powinno przebiegać etapami, od obserwacji przez dostrajanie reguł do blokowania. Każdy alarm i każdy wyjątek powinien mieć przypisanego właściciela.

3. Ocena skuteczności powinna obejmować trafność alarmów, czas reakcji i zakres pokrycia chronionych zasobów, a nie wyłącznie liczbę zablokowanych operacji.

Wnioski te mają charakter koncepcyjny. Wymagają weryfikacji w badaniach empirycznych prowadzonych w organizacjach o różnej wielkości i strukturze.

Kierunki dalszych badań obejmują przede wszystkim wykrywanie wycieków w kanałach szyfrowanych, zastosowanie uczenia głębokiego do wykrywania zagrożeń wewnętrznych oraz DLP świadczone jako usługa chmurowa z zachowaniem poufności analizowanych danych[55]. Potrzebne są też wspólne zbiory danych testowych, bez których trudno rzetelnie porównywać metody wykrywania. Osobnym zagadnieniem jest przepływ informacji do narzędzi generatywnej sztucznej inteligencji, którego skala według danych z 2025 roku szybko rośnie[56].

[52] Tamże.
[53] J. Reason, *Human error*, dz. cyt.
[54] L. Cheng, F. Liu, D. Yao, *Enterprise data breach*, dz. cyt.
[55] Tamże.
[56] Verizon, *Vulnerability exploitation top breach entry point*, dz. cyt.

Bibliografia

Alneyadi S., Sithirasenan E., Muthukkumarasamy V., *A survey on data leakage prevention systems*, „Journal of Network and Computer Applications" 2016, t. 62, https://doi.org/10.1016/j.jnca.2016.01.008.

Cheng L., Liu F., Yao D., *Enterprise data breach: causes, challenges, prevention, and future directions*, „WIREs Data Mining and Knowledge Discovery" 2017, t. 7, nr 5, e1211, https://doi.org/10.1002/widm.1211.

Chuvakin A., *Back in 2015, while working on a Gartner SOC paper, I coined the concept of „SOC nuclear triad"...*, *Anton on Security* (Medium), 2020; przedruk: Security Boulevard, wrzesień 2020, https://securityboulevard.com/2020/09/back-in-2015-while-working-on-a-gartner-soc-paper-i-coined-the-concept-of-soc-nuclear-triad/ (dostęp 21.10.2026 r.).

Fisher W. i in., *Data Confidentiality: Identifying and Protecting Assets Against Data Breaches*, NIST Special Publication 1800-28, National Institute of Standards and Technology, Gaithersburg, MD 2024, https://doi.org/10.6028/NIST.SP.1800-28.

IBM, *IBM Study: One in Four Malicious Breaches are AI-Enabled, Costing Companies $6 Million on Average*, informacja prasowa dotycząca raportu *Cost of a Data Breach Report 2026* (Ponemon Institute, IBM), 29 lipca 2026, https://newsroom.ibm.com/2026-07-29-ibm-study-one-in-four-malicious-breaches-are-ai-enabled,-costing-companies-6-million-on-average (dostęp 21.10.2026 r.).

Pathirana N. i in., *Integrating Human Factors into Insider Threat Detection: A Systematic Review*, „ACM Computing Surveys" 2026, t. 58, nr 10, https://doi.org/10.1145/3798089.

Ponemon Institute, *2026 Cost of Insider Risks: Global*, omówienie raportu *2026 Cost of Insider Risks Global Report* przygotowanego na zlecenie DTEX Systems, 13 maja 2026, https://ponemonsullivanreport.com/2026/05/2026-cost-of-insider-risks-globa (dostęp 26.10.2026 r.).

Reason J., *Human error: models and management*, „BMJ" 2000, t. 320, nr 7237, https://doi.org/10.1136/bmj.320.7237.768.

Rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (ogólne rozporządzenie o ochronie danych) (Dz.Urz. UE L 119 z 4.05.2016, s. 1–88).

Shabtai A., Elovici Y., Rokach L., *A Survey of Data Leakage Detection and Prevention Solutions*, SpringerBriefs in Computer Science, Springer, New York 2012, https://doi.org/10.1007/978-1-4614-2053-8.

Urząd Ochrony Danych Osobowych, *Prawie 240 tys. zł kary dla firmy, której pracownik zgubił pendrive z danymi osobowymi*, komunikat dotyczący decyzji Prezesa UODO DKN.5131.29.2023, 17 maja 2024, https://uodo.gov.pl/pl/138/3095 (dostęp 28.10.2026 r.).

Urząd Ochrony Danych Osobowych, *Rekordowa kara dla administratora za naruszenie ochrony danych*, komunikat dotyczący decyzji Prezesa UODO DKN.5130.2215.2020, 28 lutego 2022, https://uodo.gov.pl/pl/138/2389 (dostęp 28.10.2026 r.).

Verizon, *Vulnerability exploitation top breach entry point, 2026 industry-wide DBIR finds*, informacja prasowa dotycząca raportu *2026 Data Breach Investigations Report*, 19 maja 2026, https://www.verizon.com/about/news/breach-industry-wide-dbir-finds (dostęp 21.10.2026 r.).

Verizon Business, *2024 Data Breach Investigations Report: Appendices*, https://verizon.com/business/resources/reports/dbir/2024/appendix (dostęp 21.10.2026 r.).

Verizon Business, *2026 Data Breach Investigations Report*, 2026, https://www.verizon.com/business/resources/T343/reports/2026-dbir-data-breach-investigations-report.pdf (dostęp 26.10.2026 r.).

Nota biograficzna

dr inż. **Bartosz Lewandowski** - Dyrektor Działu Innowacji i Rozwoju w Atende S.A. oraz adiunkt w Katedrze Inżynierii Klinicznej Akademii Śląskiej. Zajmuje się sztuczną inteligencją, bezpieczeństwem i suwerennością danych oraz innowacyjnymi technologiami medycznymi i finansowymi. Posiada ponad 15-letnie doświadczenie w projektowaniu i wdrażaniu systemów informatycznych oraz zarządzaniu zespołami badawczo-rozwojowymi. Rozwija rozwiązania wykorzystujące lokalne modele językowe, architektury RAG i agentów AI, ze szczególnym uwzględnieniem cyberbezpieczeństwa, ochrony informacji i suwerenności danych. Prowadzi badania nad zastosowaniami AI w medycynie, m.in. w analizie obrazów diagnostycznych oraz predykcji, a także nad uwierzytelnianiem

bezpieczeństwa żywności metodami uczenia maszynowego. Współtworzył rozwiązania z zakresu bezpiecznego cyfrowego zarządzania dokumentami, w tym system ChainDoc oparty na technologii blockchain, realizujący wymogi trwałego nośnika w bankowości. Zespół ChainDoc otrzymał nagrodę ComputerWorld za najlepsze wdrożenie technologii blockchain oraz nagrodę Smart City Forum w kategorii usług wspólnych. Organizator „Konferencji PI" w Toruniu, prelegent na konferencjach krajowych oraz międzynarodowych.